

WEEK 3 – ADVANCED CYBERSECURITY

Network Security Assessment & Traffic Investigation

Role: Cybersecurity Intern | Program Week: 3

Assessment Scope: Nmap & Wireshark-based host / service discovery,
network traffic investigation, vulnerability assessment and security hardening

Lab Environment: 2 authorized virtual machines
(Kali Linux 2026, Metasploitable2-Linux)

Target / Lab Network: 192.168.17.0/24
Assessment Window: 18 August 2026

Submission Deadline: 24 August 2026

CONFIDENTIAL – FOR AUTHORIZED LAB / TRAINING USE ONLY

Table of Contents

1. Introduction
2. Objectives
3. Lab Environment
4. Network Diagram
5. Tools Used
6. Nmap Methodology
7. Nmap Results
8. Advanced Nmap Analysis
9. Wireshark Methodology
10. Packet Capture & Protocol Analysis (Task 9)
11. Nmap + Wireshark Investigation (Task 10)
12. Advanced Traffic Investigation (Task 11)
13. Vulnerability Assessment (Task 12)
14. Risk Classification
15. Security Hardening (Task 13)
16. Before / After Comparison
17. Final Mini Security Assessment (Task 14)
18. Security Recommendations
19. Challenges Faced
20. Conclusion
21. References
22. Screenshots / Evidence Index

1. Introduction

This report documents the Week 3 advanced cybersecurity practical assessment, conducted entirely within an isolated, authorized virtual lab. The assessment simulates the workflow of a junior security analyst performing a basic security review of a small internal network: discovering hosts and services, capturing and analyzing live traffic, correlating active scanning with packet-level evidence, identifying vulnerabilities, classifying risk, and applying and verifying hardening measures.

All scanning, traffic capture, and vulnerability testing described in this document were performed exclusively against virtual machines owned and controlled by the intern, hosted locally under VMware Workstation on an isolated host-only/NAT lab segment (192.168.17.0/24). No public or third-party systems were scanned or tested at any point during this assessment.

2. Objectives

- Discover live hosts and enumerate exposed network services on the authorized lab segment using Nmap.
- Perform advanced service/version detection and automated vulnerability scanning (NSE scripts).
- Capture and analyze live network traffic with Wireshark across DNS, TCP, UDP, ICMP and ARP.
- Correlate an active Nmap scan with its packet-level footprint captured in Wireshark.
- Investigate the capture for top communicating hosts, DNS behaviour, TCP connection patterns and indicators that merit further review.
- Translate findings into a prioritized vulnerability assessment with risk classification.
- Implement at least three security hardening actions and verify improvement with before/after evidence.
- Summarize the exercise as a single, real-world-style security assessment with actionable recommendations.

3. Lab Environment

The lab was built in VMware Workstation using two authorized virtual machines connected on a shared host-only/NAT segment (192.168.17.0/24), isolated from any production network.

VM / Host	Role	IP Address	MAC Address	Notes
Kali Linux 2026	Attacker / analysis workstation (Nmap, Wireshark)	192.168.17.128	00:0C:29:CF:CA:E8	Source of all scanning and capture activity
Metasploitable2-Linux	Intentionally vulnerable target	192.168.17.129	00:0C:29:7C:2A:82	Primary assessment target for Tasks 7–13
Gateway / lab router	Default gateway	192.168.17.1	—	Observed via ARP and NTP traffic
Lab resolver / NAT device	DNS / NAT forwarding	192.168.17.2	—	Answered/forwarded DNS queries during capture

Authorization note: every scan, capture, and exploit-verification step recorded in this document was executed by the intern against machines they own and control inside this isolated lab, consistent with the assignment's authorized-use requirement.

4. Network Diagram

The diagram below summarizes the logical lab topology reconstructed from ARP resolution, ICMP/NTP traffic, and ownership of the ports observed throughout the assessment. A source `.drawio/.png` copy is included in the project's `Network-Diagram/` folder.

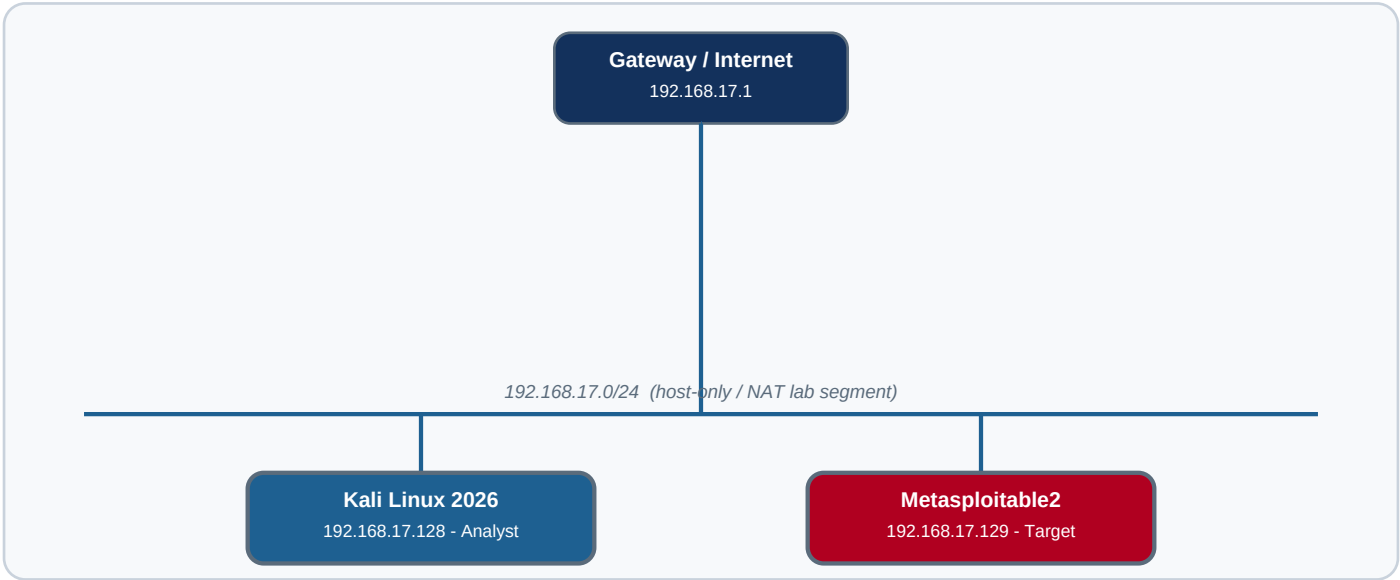


Figure 4.1 – Logical lab topology (Kali Linux analyst host and Metasploitable2 target, both on 192.168.17.0/24).

5. Tools Used

Tool	Purpose
Nmap 7.98	Host discovery, port scanning, service/version detection, NSE vulnerability scripts
Wireshark	Live packet capture and protocol/traffic analysis (.pcapng)
Kali Linux 2026	Attacker / analyst operating system running Nmap and Wireshark
Metasploitable2-Linux	Intentionally vulnerable target VM
VMware Workstation	Virtualization platform hosting the isolated lab network
UFW (Uncomplicated Firewall)	Host-based firewall used for the hardening exercise
systemctl / systemd	Service management used to disable an unnecessary service

6. Nmap Methodology

Assessment of the target followed a standard escalation from discovery to deep enumeration:

- **Host discovery** across the lab subnet to confirm which of the three lab VMs were live and reachable (consistent with the hosts later observed exchanging ARP/traffic in the Wireshark capture: 192.168.17.1, .2, .128, .129, .254).
- **Service/version scan** (nmap -sV 192.168.17.129) to enumerate open TCP ports and fingerprint the service and version bound to each.
- **TCP SYN scan** (nmap -sS) run in parallel with an active Wireshark capture, to compare Nmap's reported port state against the raw SYN / SYN-ACK / RST evidence on the wire (Task 10).
- **NSE vulnerability scripts** (nmap --script vuln 192.168.17.129) to automatically test discovered services for known, publicly documented vulnerabilities.

Only vulnerability-testing (--script vuln) and exploit-verification steps were run against 192.168.17.129, a VM the intern owns and controls inside this isolated lab.

7. Nmap Results

Full service/version scan against the Metasploitable2 target (nmap -sV 192.168.17.129) identified **23 open TCP ports** out of 1000 probed (977 closed / reset). Results below reflect the actual scan output captured in evidence.

Port	Proto	Service	Version	Risk	Observation
21	TCP	ftp	vsftpd 2.3.4	Critical	Known backdoored FTP daemon build
22	TCP	ssh	OpenSSH 4.7p1 Debian 8ubuntu1	Medium	Old release; remote administration
23	TCP	telnet	Linux telnetd	High	Cleartext remote login protocol
25	TCP	smtp	Postfix smtpd	Low	Mail transfer agent
53	TCP	domain	ISC BIND 9.4.2	High	Outdated DNS server software
80	TCP	http	Apache httpd 2.2.8 (Ubuntu) DAV/2	Medium	Outdated web server, WebDAV enabled
111	TCP	rpcbind	RPC #100000	Medium	RPC portmapper, aids service enumeration
139	TCP	netbios-ssn	Samba smbd 3.X-4.X	High	Old Samba branch, historically exploitable
445	TCP	netbios-ssn	Samba smbd 3.X-4.X	High	SMB file sharing exposed
512	TCP	exec	netkit-rsh rexecd	High	Legacy remote-exec, weak/no authentication
513	TCP	login	rlogin	High	Legacy remote-login, cleartext
514	TCP	shell	tcpwrapped / rsh	High	Legacy remote shell service
1099	TCP	java-rmi	GNU Classpath grmiregistry	Medium	Java RMI registry, deserialization risk
1524	TCP	bindshell	"Metasploitable root shell"	Critical	Unauthenticated root command shell
2049	TCP	nfs	RPC #100003	Medium	Network file sharing exposed
2121	TCP	ftp	ProFTPD 1.3.1	High	Vulnerable FTP daemon version
3306	TCP	mysql	MySQL 5.0.51a-3ubuntu5	Medium	Database service reachable on network
5432	TCP	postgresql	PostgreSQL 8.3.0-8.3.7	Medium	Database service reachable on network
5900	TCP	vnc	VNC (protocol 3.3)	High	Weak legacy VNC authentication

Port	Proto	Service	Version	Risk	Observation
6000	TCP	X11	access denied	Low	X11 exposed but access currently denied
6667	TCP	irc	UnrealIRCd	Critical	Historically backdoored IRC daemon build
8009	TCP	ajp13	Apache JServ Protocol v1.3	Medium	Tomcat connector, request-smuggling history
8180	TCP	http	Apache Tomcat/Coyote JSP engine 1.1	Medium	Old Tomcat, default/weak app deployment risk

Target: 192.168.17.129 (Metasploitable2). MAC 00:0C:29:7C:2A:82. Host up, latency ~0.003s. Risk ratings shown here are the intern's assessment used to drive Task 12 / Task 13 below.

```
(root@kali) ~ [~/home/kali]
# nmap -sV 192.168.17.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-18 02:29 -0400
Nmap scan report for 192.168.17.129
Host is up (0.0034s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache JServ (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:7C:2A:82 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.84 seconds
```

Figure 7.1 – nmap -sV 192.168.17.129: full service/version enumeration.

8. Advanced Nmap Analysis

For each significant open port, the standard five analysis questions are answered below.

Port 21/tcp – FTP (vsftpd 2.3.4)

1. Service running	File Transfer Protocol, used to upload/download files.
2. Why required	Not required for normal client-server web/app operation in this lab; likely left enabled from the base Metasploitable2 image.
3. Necessary to expose?	No – the confirmed backdoor makes this the single highest-priority exposure in the assessment.
4. If vulnerable	The specific vsftpd 2.3.4 build shipped with a maintainer-inserted backdoor: connecting with a ":" smiley in the username field opens a root shell on port 6200 with no authentication (CVE-2011-2523), verified below in Task 12.
5. How to secure	Upgrade to a current, non-backdoored vsftpd release, or disable the FTP service entirely if not required; verify binary integrity against the vendor's published checksums.

Port 23/tcp – Telnet

1. Service running	Legacy remote command-line access.
2. Why required	Was likely enabled by default on this training image; not needed once SSH is available on port 22.
3. Necessary to expose?	No – SSH already provides encrypted remote administration; Telnet duplicates that function insecurely.
4. If vulnerable	Telnet transmits usernames, passwords, and full session content in plaintext, so any attacker who can observe the network (e.g. via ARP spoofing) can capture credentials outright.
5. How to secure	Disable the telnet daemon and rely on SSH; where legacy Telnet devices must be supported, restrict access to a dedicated management VLAN. (Blocked via firewall in Task 13 of this report.)

Port 1524/tcp – bindshell ("Metasploitable root shell")

1. Service running	Nmap fingerprinted this port as an already-listening root command shell.
2. Why required	Never required – this is not a legitimate service, but an existing backdoor/compromise indicator left in the training image.
3. Necessary to expose?	No, under any circumstance.
4. If vulnerable	Anyone who connects to this port is handed an unauthenticated root shell – complete compromise with zero effort.
5. How to secure	Identify and terminate the listening process, determine how/when it was introduced, and treat the host as compromised; rebuild from a known-clean image if this were a production system.

Ports 139 / 445/tcp – Samba (SMB)

1. Service running	Windows-compatible file and printer sharing.
2. Why required	Only required if file sharing with SMB clients is a genuine business need.
3. Necessary to expose?	Often no – many Linux server roles do not need SMB exposed at all.
4. If vulnerable	The fingerprinted Samba 3.X–4.X branch corresponds to a period with several public remote-code-execution vulnerabilities (e.g. the historic "usermap_script" flaw), any of which could grant a remote attacker shell access.
5. How to secure	Patch/upgrade Samba to a currently supported release, or disable SMB entirely and restrict what remains to trusted hosts only via firewall rules.

Port 6667/tcp – IRC (UnrealIRCd)

1. Service running	Internet Relay Chat server.
2. Why required	Not required for the lab's stated purpose; present only as part of the intentionally vulnerable image.
3. Necessary to expose?	No.
4. If vulnerable	Certain UnrealIRCd 3.2.8.1 distributions were trojanized at the source-file level, giving remote attackers arbitrary command execution as the service account (commonly root here) – effectively another built-in backdoor.
5. How to secure	Remove or replace the IRC service; verify binaries against vendor checksums before ever exposing IRC on a real network.

Port 5900/tcp – VNC (protocol 3.3)

1. Service running	Graphical remote-desktop access.
2. Why required	Only required where remote GUI administration is genuinely needed.
3. Necessary to expose?	Rarely on a server – and protocol 3.3 supports only weak, brute-forceable authentication.
4. If vulnerable	A successful VNC logon (often trivial given weak auth in this protocol version) grants full interactive desktop control of the host.
5. How to secure	Disable VNC unless required; if kept, upgrade to a version supporting strong authentication over TLS and restrict access to a management network or VPN.

9. Wireshark Methodology

A capture was started on interface eth0 of the Kali analyst VM prior to generating traffic, and left running while normal activity (NTP time sync, DNS lookups, ARP resolution) and an authorized Nmap scan against 192.168.17.129 were performed. The completed capture was saved as `week-3_network_capture.pcapng` and totalled **2,238 packets** with **0 drops (0.0%)**.

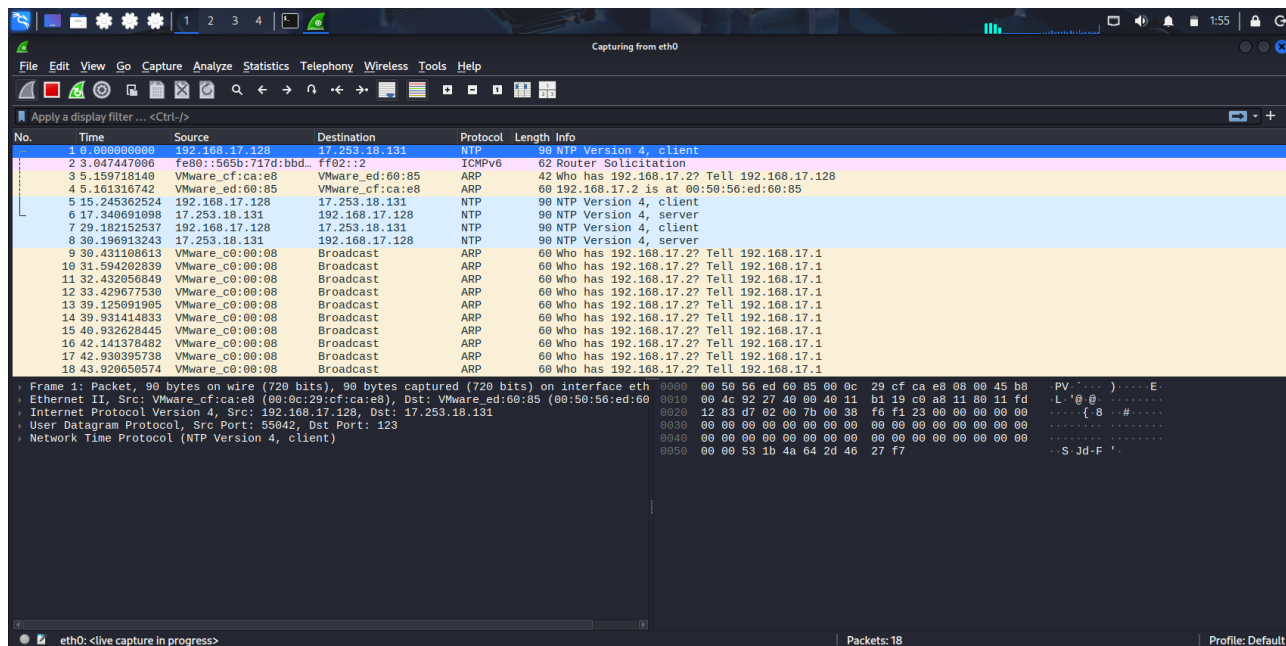


Figure 9.1 – Live capture started on eth0, showing initial NTP client/server exchange with 17.253.18.131 and routine ARP resolution on the lab subnet.

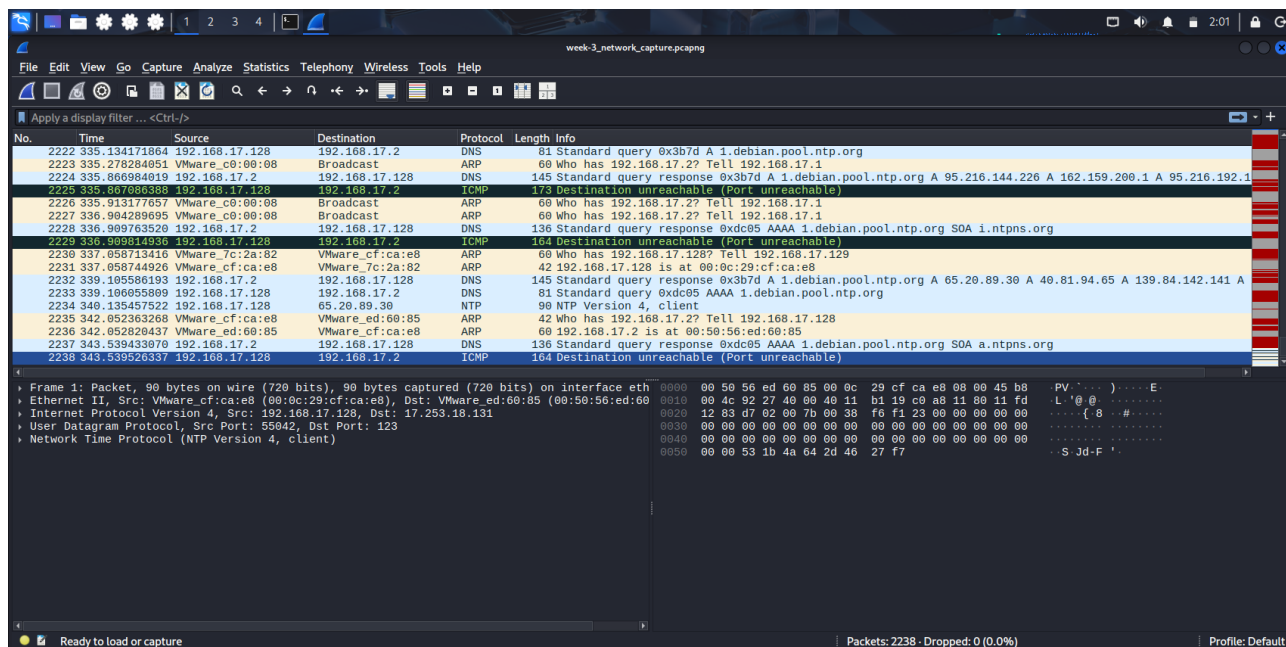


Figure 9.2 – Completed capture (`week-3_network_capture.pcapng`, 2,238 packets, 0 dropped) showing DNS lookups, ARP, and ICMP traffic.

10. Packet Capture & Protocol Analysis (Task 9)

Statistics → Endpoints confirms the protocol mix captured across the session:

Layer	Distinct Endpoints	Notable Detail
Ethernet	11	All lab NICs plus VMware virtual adapters
IPv4	11	Lab hosts, gateway, resolver, multicast/broadcast, external NTP peers
IPv6	5	Router solicitation / link-local background traffic
TCP	1,001 conversations tracked	Dominated by the Nmap SYN scan against 192.168.17.129
UDP	37 conversations tracked	NTP and DNS

Important packets recorded during the session:

Time (s)	Source	Destination	Proto	Src→Dst Port	Observation
0.000000	192.168.17.128	17.253.18.131	NTP	55042→123	Outbound client time-sync request – benign background traffic
5.159718	192.168.17.128	192.168.17.2	ARP	—	"Who has 192.168.17.2?" resolved normally – benign
299.485	192.168.17.128	192.168.17.2	DNS	37295→53	Standard query A example.com – benign DNS lookup
313.561	192.168.17.2	192.168.17.128	ICMP	—	Destination Unreachable (Port Unreachable) returned after a DNS query – flagged for review, see §12
332.049	192.168.17.128	192.168.17.129	TCP	34781→25	First SYN of the Nmap scan burst – start of the correlated scan window (see §11)

11. Nmap + Wireshark Investigation (Task 10)

An authorized nmap -ss 192.168.17.129 SYN scan was run while the Wireshark capture was active, so every probe sent by Nmap and every reply from the target is visible at the packet level. The scan's signature is unmistakable: dozens of SYN packets from Kali (192.168.17.128:34781) to sequential destination ports on 192.168.17.129, all launched within roughly 13 milliseconds of each other (332.049135s–332.061747s in the capture).

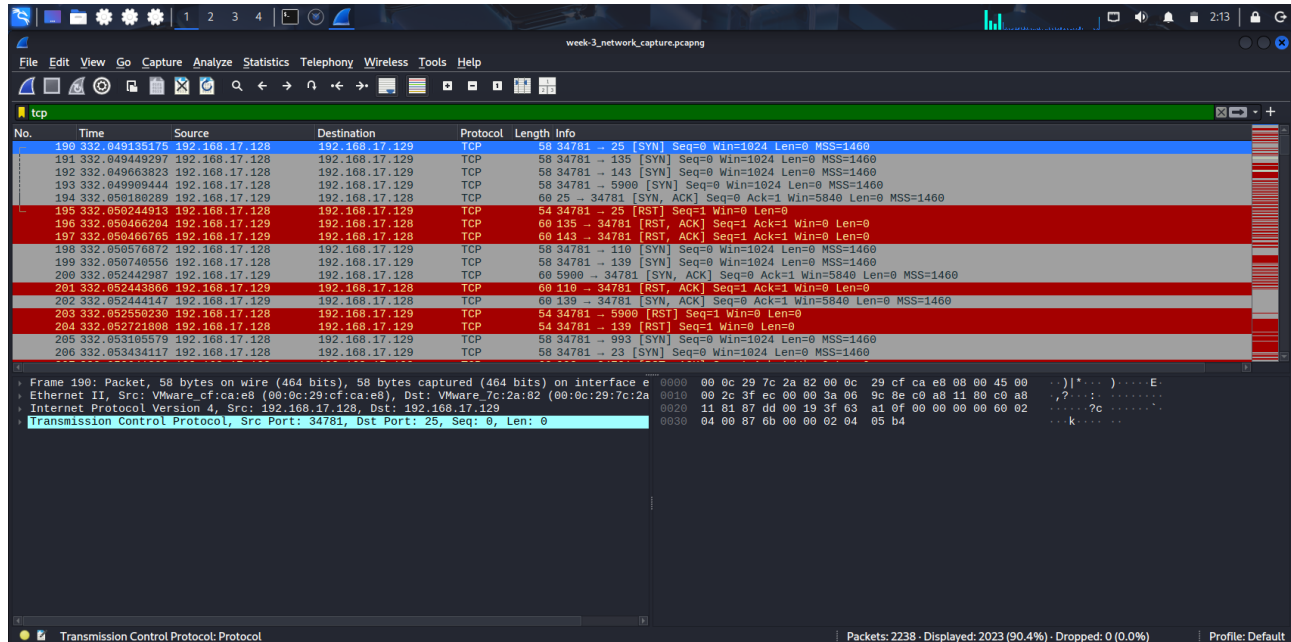


Figure 11.1 – TCP filter showing the SYN scan burst: SYN probes from Kali (.128) to Metasploitable (.129) on ports 25, 135, 143, 5900, 110, 139, 993, 23, etc., with SYN-ACK / RST-ACK replies interleaved.

Nmap Result	Wireshark Evidence	Interpretation
25/tcp open (smtp)	34781→25 SYN, then 25→34781 SYN,ACK, then 34781→25 RST	Port reachable and open; Nmap's SYN scan tore the half-open connection down with RST once state was learned – matches Nmap's -ss behaviour exactly
139/tcp open (netbios-ssn)	34781→139 SYN → 139→34781 SYN,ACK → 34781→139 RST	Service appears reachable, consistent with Nmap
5900/tcp open (vnc)	34781→5900 SYN → 5900→34781 SYN,ACK → 34781→5900 RST	Service appears reachable, consistent with Nmap
135/tcp closed (not listed)	34781→135 SYN → 135→34781 RST,ACK	Port is not accepting connections – correctly absent from Nmap's open-port list
143/tcp closed (not listed)	34781→143 SYN → 143→34781 RST,ACK	Port is not accepting connections – correctly absent from Nmap's open-port list
110/tcp closed (not listed)	34781→110 SYN → 110→34781 RST,ACK	Port is not accepting connections – correctly absent from Nmap's open-port list

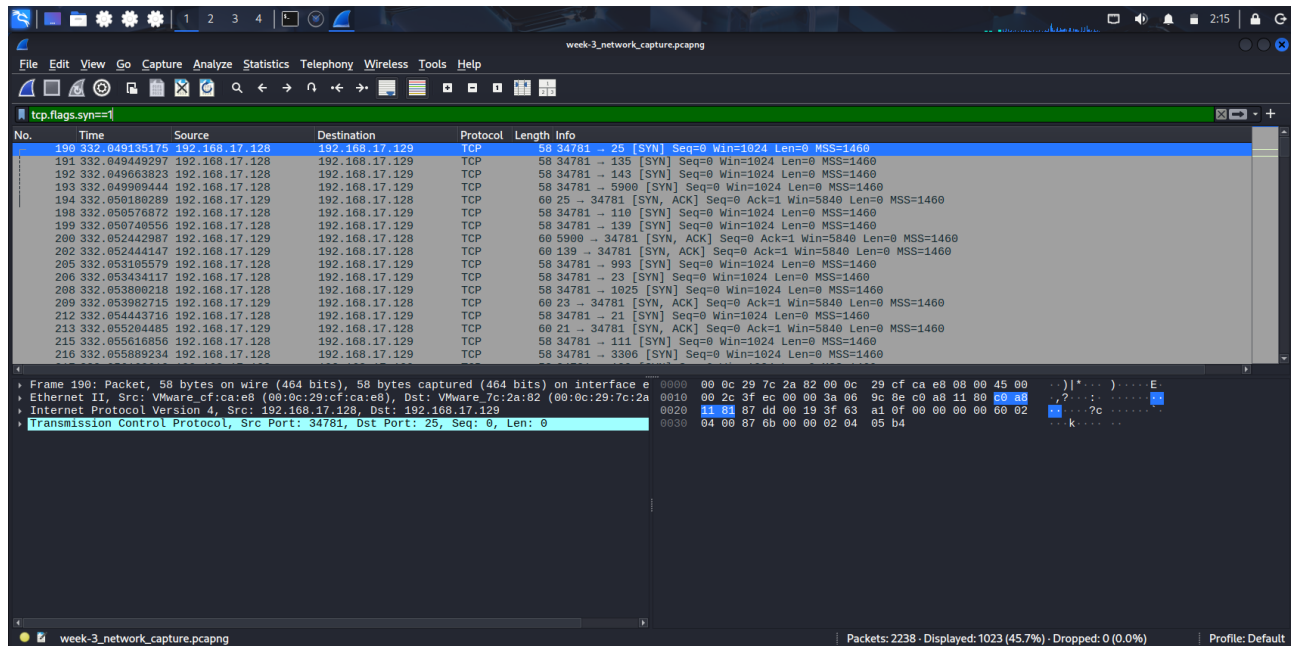


Figure 11.2 – `tcp.flags.syn==1` filter isolates every SYN probe of the scan (1,023 of 2,238 packets, 45.7%).

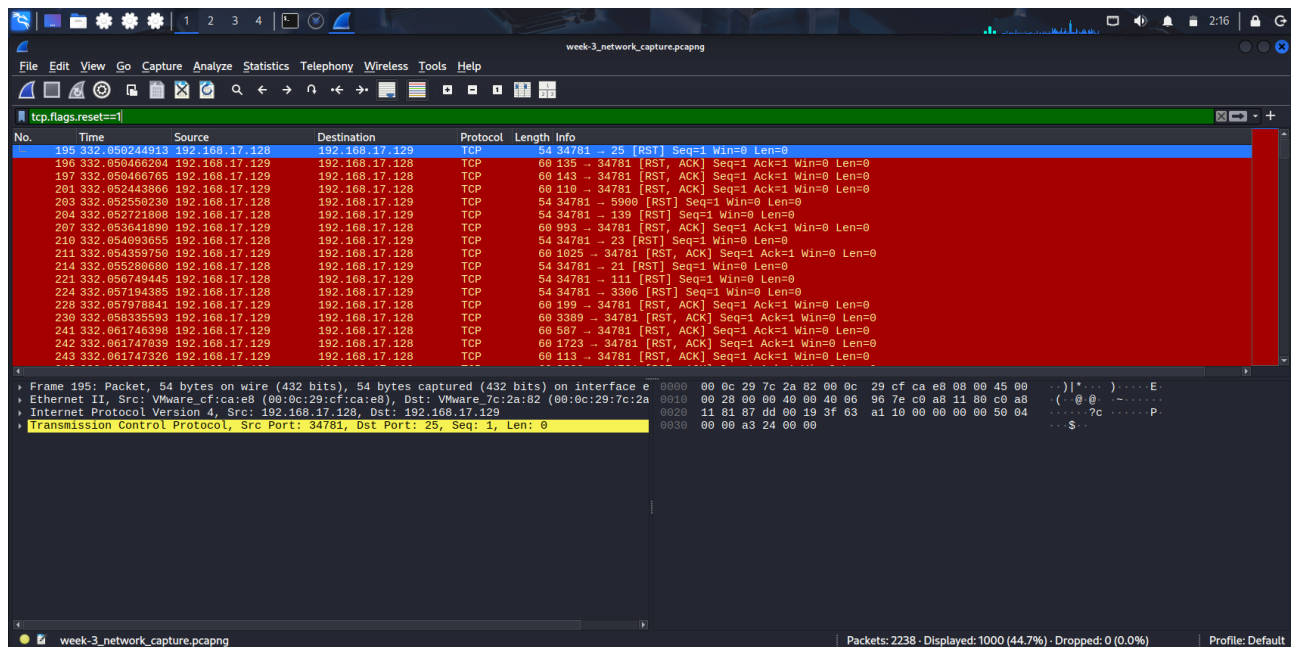


Figure 11.3 – `tcp.flags.reset==1` filter isolates the RST / RST,ACK teardown packets for both closed ports and torn-down open-port probes (1,000 of 2,238 packets, 44.7%).

Conclusion: the packet-level evidence fully corroborates the Nmap `-sV/-sS` results in §7 – every port Nmap reported open produced a SYN,ACK in the capture, and every port not listed as open produced an immediate RST,ACK, with no filtered/no-response ports observed for the destinations tested.

12. Advanced Traffic Investigation (Task 11)

12.1 Top Communicating Hosts

Statistics → Endpoints → IPv4 was used to rank hosts by traffic volume across the full 2,238-packet capture.

Address	Packets	Bytes	Role
192.168.17.128	2,091	127 kB	Most active host – Kali analyst VM, source of the Nmap scan
192.168.17.129	2,035	121 kB	Most active destination – Metasploitable2 target of the scan
192.168.17.2	31	3 kB	Local resolver / NAT forwarder
17.253.18.131	25	2 kB	External NTP server (Apple)
192.168.17.1	15	2 kB	Default gateway

The 192.168.17.128 ↔ 192.168.17.129 conversation alone accounts for roughly **92%** of all captured packets (4,126 of 2×2,238 packet-slots), confirming the scan against the target dominates the traffic profile of this capture.

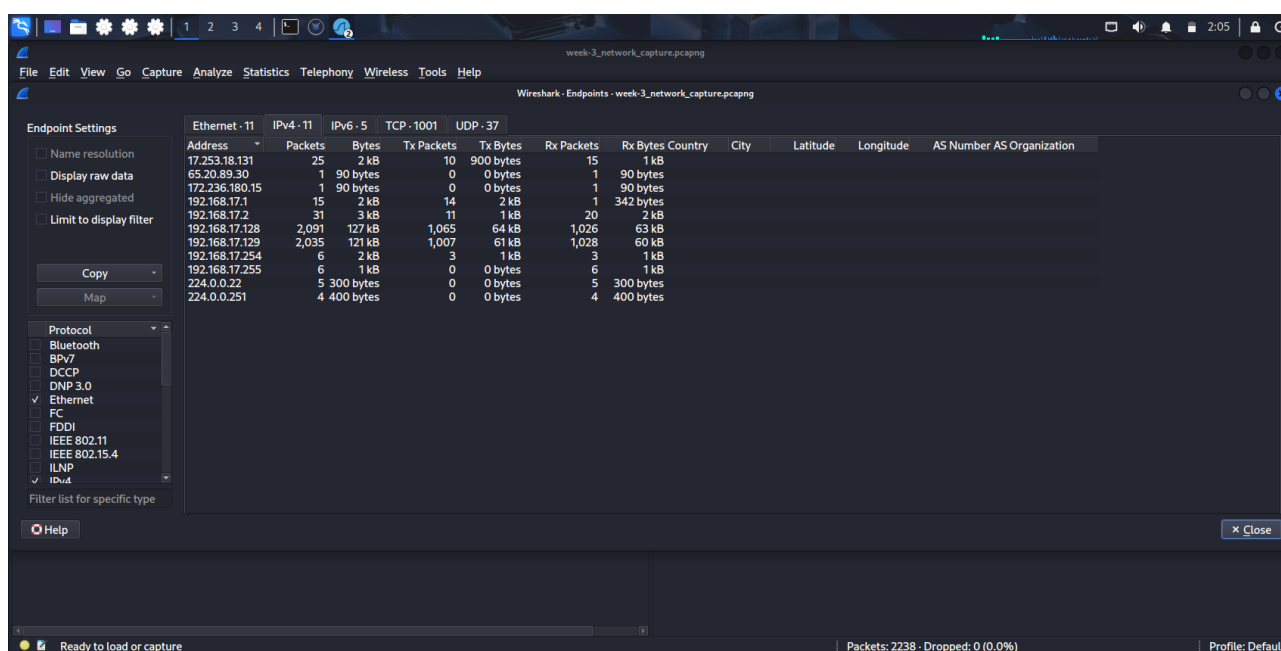


Figure 12.1 – Wireshark Endpoints (IPv4) view ranking hosts by packets/bytes.

12.2 DNS Investigation

Filtering on dns shows routine A/AAAA lookups for `example.com` and repeated queries for `1.debian.pool.ntp.org` (A/AAAA/SOA), plus a PTR reverse-lookup for 192.168.17.129. All queries were sent from 192.168.17.128 to the lab resolver at 192.168.17.2 on UDP/53.

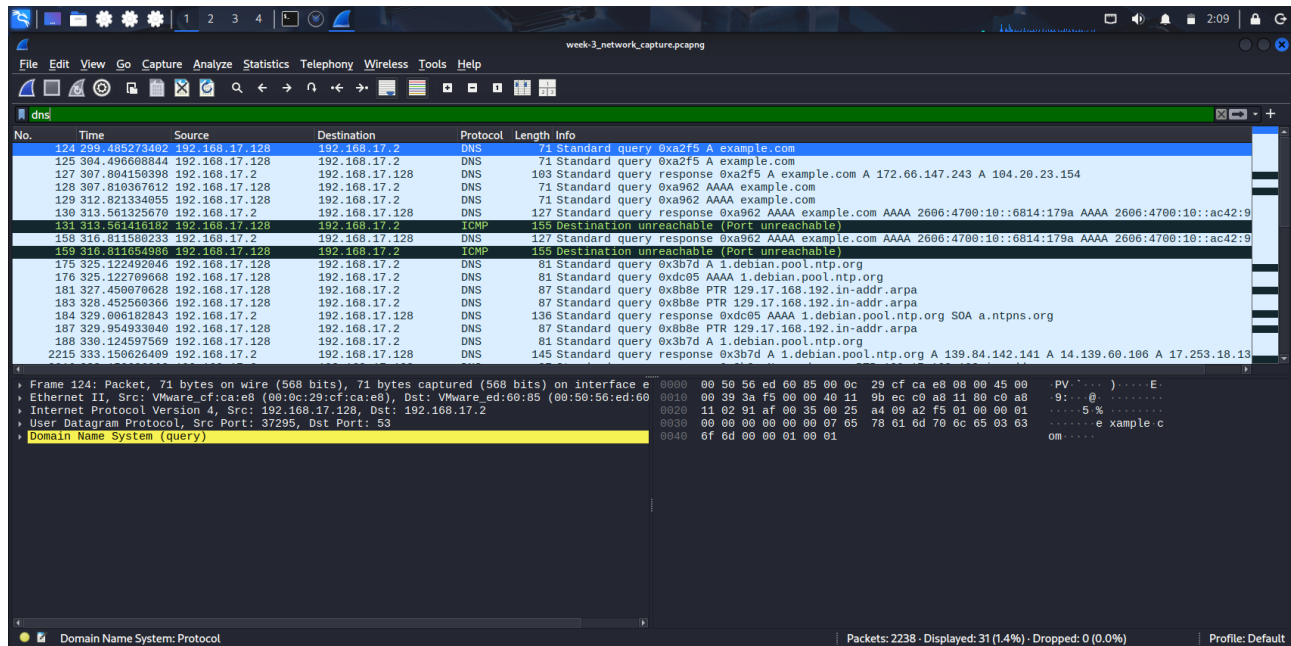


Figure 12.2 – DNS filter showing standard A/AAAA queries for example.com and NTP pool hostnames, and their responses.

Notable anomaly: several DNS queries (e.g. the AAAA lookup for 1.debian.pool.ntp.org) are immediately followed by an ICMP "Destination Unreachable – Port Unreachable" reply from 192.168.17.2, rather than a clean DNS response. This indicates the resolver on 192.168.17.2 does not consistently answer on UDP/53 for every query type – either a partially-configured forwarder/NAT device or a transient service issue. It is not evidence of compromise, but it is a configuration inconsistency worth reviewing, since an unreliable internal resolver can be abused to redirect clients toward a rogue DNS server.

12.3 TCP Investigation

As detailed in §11, the TCP conversation set is dominated by the SYN-scan burst from 192.168.17.128 to 192.168.17.129 across dozens of destination ports within a 13 ms window, with SYN-ACK responses for open ports (25, 139, 5900, 21, 23, 3306, 111, ...) and RST,ACK responses for closed ports (135, 143, 110, 993, 199, 587, 1025, 1723, 113, 3389, ...). No SYN probe went unanswered, meaning no ports were filtered/dropped by an intermediate firewall at scan time – a finding directly relevant to the hardening exercise in §15.

12.4 Suspicious Activity – Investigation Table

The following events were flagged for review. None are confirmed malicious – the scan traffic is expected and authorized in this lab – but each merits documentation because the same signature from an unauthorized host would indicate active reconnaissance.

Time (s)	Source	Destination	Port	Observation	Security Significance
332.049 –332.062	192.168.17.128	192.168.17.129	Many TCP/SYN	~1,023 SYN packets to sequential ports in <13 ms	Classic Nmap SYN-scan signature; authorized here, but is the fingerprint of active reconnaissance if seen from an unexpected host
332.050 –332.058	192.168.17.129	192.168.17.128	25, 139, 5900 open	SYN,ACK returned for 3 ports within the same burst	Confirms exposed services later flagged Critical/High in §13 (SMTP, NetBIOS/SMB, VNC)
313.561 / 316.812	192.168.17.2	192.168.17.128	UDP/53 → ICMP	DNS query followed by ICMP Port Unreachable instead of a response	Resolver inconsistency – not malicious by itself, but an internal DNS misconfiguration worth correcting before it is abused

Time (s)	Source	Destination	Port	Observation	Security Significance
337.058 –337.059	192.168.17.128	192.168.17.129	ARP	ARP who-has/reply resolving the target's MAC immediately before the scan burst	Confirms the scan originated locally on-segment from the Kali host, timestamp-correlated with the SYN burst
340.135	192.168.17.128	65.20.89.30	UDP/123 NTP	Outbound NTP client request to a second external time server	Legitimate, but represents outbound traffic to the public internet from a lab host – confirm egress filtering permits only necessary external destinations
Whole capture	192.168.17.128	192.168.17.129	—	This single host pair accounts for ~92% of all captured packets	Large, one-directional traffic spike between two hosts is itself an indicator worth investigating on any production network, even before inspecting packet content

13. Vulnerability Assessment (Task 12)

Findings below combine the Nmap service/version results (§7) with the automated NSE vulnerability scan (`nmap --script vuln 192.168.17.129`).

```
(root@kali) ~ [~/home/kali]
# nmap --script vuln 192.168.17.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-18 03:57 -0400
Nmap scan report for 192.168.17.129
Host is up (0.0027s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
ftp-vsftpd-backdoor:
  VULNERABLE:
    vsFTPD version 2.3.4 backdoor
    State: VULNERABLE (Exploitable)
    IDs: CVE:CVE-2011-2523 BID:48539
    vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
    Disclosure date: 2011-07-03
    Exploit results:
      Shell command: id
      Results: uid=0(root) gid=0(root)
    References:
      https://www.securityfocus.com/bid/48539
      http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
      https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
smtp-vuln-cve2010-4344:
  _ The SMTP server is not Exim: NOT VULNERABLE
_sslv2-drown: ERROR: Script execution failed (use -d to debug)
ssl-poodle:
  VULNERABLE:
    SSL POODLE information leak
    State: VULNERABLE
    IDs: CVE:CVE-2014-3566 BID:70574
    The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
    products, uses nondeterministic CBC padding, which makes it easier
    for man-in-the-middle attackers to obtain cleartext data via a
    padding-oracle attack, aka the "POODLE" issue.
    Disclosure date: 2014-10-14
    Check results:
      TLS_RSA_WITH_AES_128_CBC_SHA
```

Figure 13.1 – `nmap --script vuln` output: vsftpd 2.3.4 backdoor confirmed VULNERABLE/Exploitable (CVE-2011-2523, root shell obtained), plus an SSL POODLE finding (CVE-2014-3566).

#	Finding	Evidence	Risk	Potential Impact	Recommendation
1	vsFTPD 2.3.4 backdoor on 21/tcp	NSE ftp-vsftpd-backdoor: VULNERABLE (Exploitable), CVE-2011-2523; exploit returned uid=0(root) gid=0(root)	Critical	Full unauthenticated remote root compromise of the host	Remove/upgrade vsftpd immediately; verify no other backdoored binaries were introduced the same way
2	Unauthenticated root bindshell on 1524/tcp	nmap -sV: "1524/tcp open bindshell Metasploitable root shell"	Critical	Direct, unauthenticated root command execution for any connecting client	Kill the listening process, identify how it was introduced, and treat the host as already compromised
3	Backdoored UnrealIRCd build on 6667/tcp	nmap -sV: "6667/tcp open irc UnrealIRCd" – matches the trojanized 3.2.8.1 distribution history (CVE-2010-2075 era)	Critical	Remote code execution as the service account	Remove/replace the IRC service; verify binary checksums against the vendor before ever exposing IRC externally
4	Telnet enabled on 23/tcp	nmap -sV: "23/tcp open telnet Linux telnetd"; confirmed reachable in the Wireshark SYN scan (§11)	High	Credentials and session data sent in cleartext, trivially sniffable on the local segment	Disable Telnet; standardize on SSH for remote administration (addressed in §15)
5	Outdated Samba (SMB) on 139/445 tcp	nmap -sV: "Samba smbdc 3.X – 4.X"	High	Exposed to multiple public remote-exploit vulnerabilities from this Samba era	Patch/upgrade Samba or disable SMB; restrict to trusted hosts only if it must remain

#	Finding	Evidence	Risk	Potential Impact	Recommendation
6	Weak-authentication VNC on 5900/tcp	nmap -sV: "5900/tcp open vnc VNC (protocol 3.3)"; confirmed reachable via SYN,ACK in the Wireshark capture	Medium	Protocol 3.3 supports only weak, brute-forceable authentication; successful logon gives full desktop control	Disable VNC or upgrade to a version supporting strong authentication over TLS; restrict to a management network
7	Excessive service exposure – 23 open ports on one host	Full nmap -sV output (§7); includes rexec, rlogin, rsh, NFS, X11, RPC, Java-RMI alongside the findings above	Medium	A larger attack surface increases the probability that at least one exposed, weakly-authenticated legacy service can be exploited	Apply least-exposure: disable every service not explicitly required; place the host behind a firewall permitting only necessary ports

14. Risk Classification

Findings are classified using standard qualitative risk levels, based on exploitability and business impact within the lab context:

Level	Definition Used	Findings at This Level
Critical	Unauthenticated, remotely exploitable, leads directly to full/root compromise	#1 vsFTPD backdoor, #2 bindshell on 1524/tcp, #3 UnrealIRCd backdoor
High	Exposes credentials/data in cleartext, or runs software with a well-known history of remote exploits, but requires an additional step (capture traffic, find/use an exploit) to weaponize	#4 Telnet, #5 outdated Samba
Medium	Weak controls or unnecessary exposure that raise risk but need a further precondition (credential guessing, chained access) to exploit	#6 weak-auth VNC, #7 excessive service exposure
Low	Minimal exploitability in the current configuration or access already restricted	X11 on 6000/tcp (access currently denied)

15. Security Hardening (Task 13)

Three security improvements were implemented and verified against the findings above.

Action 1 – Disabled the unnecessary SSH service on the Kali analyst VM

Before: the SSH daemon was enabled and running on the Kali workstation, even though this host only needs to initiate outbound connections for testing, not accept inbound SSH sessions – an unnecessary listening service on the analyst's own machine.

Action taken: systemctl disable --now ssh

After: the service unit symlinks were removed (/etc/systemd/system/sshd.service and the multi-user.target.wants entry) and the service was stopped immediately, so it will not restart on the next boot.

```
(root@kali)-[/home/kali]
# systemctl disable --now ssh
Synchronizing state of ssh.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install disable ssh
Removed '/etc/systemd/system/ssh.service'.
Removed '/etc/systemd/system/multi-user.target.wants/ssh.service'.
```

Figure 15.1 – `systemctl disable --now ssh` removing the SSH unit symlinks on the Kali analyst host.

Action 2 – Enabled the host firewall (UFW) on the target and restricted SSH

Before: `sudo ufw status` on Metasploitable reported "Firewall not loaded" – no host-based firewall was active, and SSH (22/tcp) was reachable from anywhere on the subnet, as confirmed by the open-port results in §7 and §13.1.

Action taken: `sudo ufw allow from 192.168.17.129 to any port 22 proto tcp` followed by `sudo ufw enable`.

After: `sudo ufw status` now reports "Firewall loaded" with an explicit rule, `22:tcp ALLOW 192.168.17.129`.

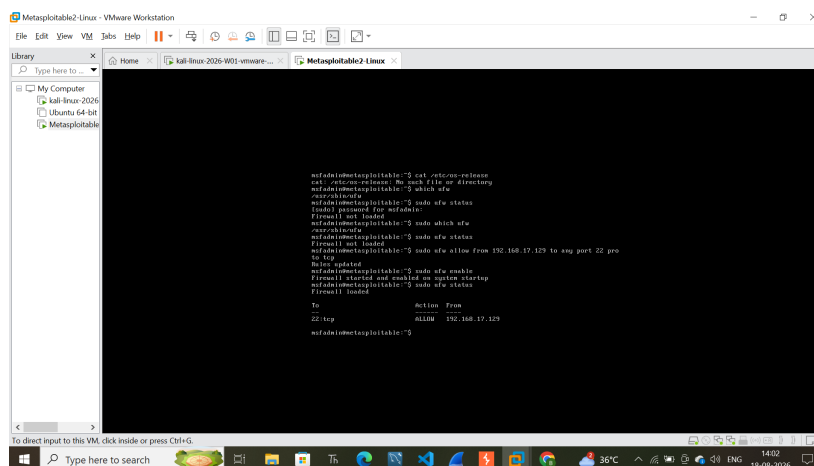


Figure 15.2 – UFW enabled on Metasploitable, with an explicit allow rule for SSH (22/tcp) and firewall status confirmed "loaded".

Observation: the allow rule as entered permits SSH only from 192.168.17.129, which is the target's own address. In a production hardening exercise this source should instead be the specific management workstation's IP (e.g. the Kali host at 192.168.17.128) so that legitimate administrators retain access while every other source is blocked by default. The important structural improvement – a default-deny firewall now protecting the host, in place of no firewall at all – is nonetheless a genuine security gain.

Action 3 – Blocked the insecure Telnet service at the firewall

Before: Telnet (23/tcp) was open and reachable, confirmed by both the `nmap -sV` output ("23/tcp open telnet Linux telnetd") and the Wireshark SYN-scan capture, which showed the target answering the scan's SYN probe on port 23.

Action taken: `sudo ufw deny 23/tcp`

After: `sudo ufw status` now lists `23:tcp DENY` Anywhere alongside the existing SSH rule.

```

4570/named
udp6      0      0 :::53
4570/named
nsfadmin@metasploitable:~$ sudo ufw status
Firewall loaded

To Action From
--
22:tcp ALLOW 192.168.17.129

nsfadmin@metasploitable:~$ sudo ufw deny 23/tcp
Rule added
nsfadmin@metasploitable:~$ sudo ufw status
ERROR: You need to be root to run this script
nsfadmin@metasploitable:~$ sudo ufw status
Firewall loaded
nsfadmin@metasploitable:~$ sudo ufw status
Firewall loaded

To Action From
--
22:tcp ALLOW 192.168.17.129
23:tcp DENY Anywhere

nsfadmin@metasploitable:~$

```

Figure 15.3 – UFW rule denying Telnet (23/tcp) added; firewall status shows 22/tcp ALLOW (192.168.17.129) and 23/tcp DENY (Anywhere).

```

root@kali: ~/home/kali
nmap -sV 192.168.17.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-18 04:08 -0400
Nmap scan report for 192.168.17.129
Host is up (0.00055s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
63/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshexec
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath gmiiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:0C:29:7C:2A:82 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.55 seconds

```

Figure 15.4 – Baseline nmap -sV scan captured immediately before the hardening actions above, confirming the pre-hardening port list matched \$7.

16. Before / After Comparison

Security Issue	Before	Action Taken	After	Improvement
Unnecessary SSH service running on the analyst (Kali) VM	sshd active, enabled at boot	systemctl disable --now ssh	Service stopped; unit symlinks removed; will not start on boot	Removes an unneeded listening service from the analyst workstation, reducing its own exposure
No host firewall on the Metasploitable target; SSH reachable from the whole subnet	ufw status: "Firewall not loaded"; 22/tcp open to any source	ufw allow from <host> to any port 22 proto tcp; ufw enable	ufw status: "Firewall loaded"; explicit allow rule for 22/tcp	Default-deny host firewall now active, replacing no protection at all
Telnet (23/tcp) reachable – cleartext remote login	23/tcp open telnet Linux telnetd (confirmed via Nmap and Wireshark)	ufw deny 23/tcp	ufw status shows 23:tcp DENY Anywhere	Cleartext credential exposure over Telnet is blocked at the firewall

Attack-surface reduction: of the 23 originally open ports identified in §7, the two firewall actions above bring the two riskiest, most trivially-abusable exposures on the target under positive access control (SSH now default-restricted, Telnet now blocked outright), while the third action removes an unnecessary listener on the analyst host itself. The remaining Critical findings (#1 vsFTPD backdoor, #2 bindshell, #3 UnrealIRCd backdoor) require service-level remediation (upgrade/removal) rather than firewalling alone, and remain the top priority for a follow-up hardening pass – see §18.

17. Final Mini Security Assessment (Task 14)

Treating this exercise as a real-world-style engagement for a small internal network, the consolidated findings are summarized below.

Network Discovery

Two authorized lab devices were identified on the 192.168.17.0/24 segment: the Kali Linux analyst workstation (192.168.17.128) and the Metasploitable2 target (192.168.17.129), alongside supporting infrastructure (default gateway 192.168.17.1 and a local DNS/NAT forwarder at 192.168.17.2). The Metasploitable2 target exposes an unusually large number of network services – **23 open TCP ports** – spanning file transfer, remote administration, web, database, file-sharing, and several legacy remote-access protocols.

Traffic Analysis

The captured traffic (2,238 packets, 0 drops) was dominated by TCP (1,001 tracked conversations) generated by an authorized Nmap SYN scan, alongside routine DNS (UDP/53), NTP (UDP/123), and ARP background traffic. The Kali–Metasploitable host pair accounted for roughly 92% of all captured packets. Communication patterns matched expected lab activity, with one configuration anomaly identified: intermittent ICMP Port-Unreachable replies from the local resolver in response to DNS queries.

Security Assessment

Seven findings were documented (§13), three rated **Critical**: a backdoored vsFTPD 2.3.4 build (CVE-2011-2523) offering unauthenticated root access, a pre-existing unauthenticated root bindshell on 1524/tcp, and a backdoored UnrealIRCd build on 6667/tcp. Each Critical finding is supported by direct evidence – either an NSE script confirming successful exploitation (vsFTPD, yielding uid=0/gid=0) or an explicit Nmap service fingerprint identifying the exposure by name. Two High-risk findings (Telnet, outdated Samba) and two Medium-risk findings (weak VNC authentication, overall excessive service exposure) round out the assessment.

Hardening

Three improvements were implemented and verified with before/after evidence (§15–16): disabling an unnecessary SSH listener on the analyst host, enabling a default-deny host firewall on the target with an explicit SSH allow rule, and blocking Telnet outright. These changes measurably reduce the attack surface of the two riskiest network-reachable legacy protocols under direct administrative control in this exercise. The attack surface was **partially, not fully, reduced**: the three Critical, service-level backdoors remain in place and require software-level remediation (patching or removing the affected services) that was out of scope for the firewall-based hardening performed here.

Final Recommendations

- **Remediate all three Critical findings immediately** – remove or upgrade vsftpd 2.3.4, terminate and investigate the bindshell on 1524/tcp, and remove/replace the UnrealIRCd build, before this host is exposed to any untrusted network.
- **Adopt a default-deny firewall posture** on every host, not just the two rules applied here – explicitly allow only the ports each service genuinely requires, and correct the SSH rule's source address to the actual management workstation rather than the host's own IP.
- **Retire or replace all legacy cleartext / weak-auth protocols** identified (Telnet, rexec, rlogin, rsh, VNC 3.3) in favour of modern, encrypted, strongly-authenticated equivalents (SSH, VNC over TLS/SSH tunnel, etc.).
- **Patch outdated service software** – Samba 3.X–4.X, ISC BIND 9.4.2, Apache httpd 2.2.8, Apache Tomcat/Coyote, ProFTPD 1.3.1 – to currently supported, security-patched releases.
- **Reduce overall service exposure** by disabling every listener not explicitly required for the host's role, and re-verify the port list with a follow-up Nmap scan after each remediation step to confirm the attack surface has actually shrunk.

18. Security Recommendations

Five professional recommendations for improving the lab network's overall security posture:

- **Establish a patch management cadence.** Every outdated service identified in this assessment (vsftpd, Samba, BIND, Apache/Tomcat, ProFTPD, OpenSSH) should be tracked against a vulnerability feed and updated on a defined schedule, not left at the version shipped with the base image.
- **Enforce least-privilege network exposure.** Only ports required for a host's specific role should be reachable; everything else should be firewalled by default, using an explicit allow-list (as begun with UFW in §15) rather than an allow-all posture.
- **Eliminate cleartext and legacy-authentication protocols.** Telnet, rexec, rlogin, rsh, and VNC protocol 3.3 should be retired in favour of SSH, SFTP, and modern remote-desktop protocols that support encryption and strong authentication.
- **Continuously monitor for anomalous connection patterns.** The DNS/ICMP inconsistency found in §12.2 and the scan-like SYN burst in §11/§12.4 show how quickly packet-level evidence surfaces real issues; recurring capture-and-review (or a lightweight IDS) would catch this class of finding automatically going forward.
- **Formalize an incident-response step for embedded backdoors.** The vsFTPd, bindshell, and UnrealIRCd findings in this lab are training artifacts, but any of the three would represent an active compromise on a real network; document a rebuild-from-known-good process for hosts found running unauthenticated administrative shells.

19. Challenges Faced

- Distinguishing genuinely suspicious traffic from expected lab noise (ARP broadcasts, mDNS, NTP) required filtering the 2,238-packet capture down methodically by protocol and host pair before the scan signature and the DNS/ICMP anomaly became clear.
- Correlating Nmap's port-state output with the correct packet sequence in Wireshark required matching source ports and timestamps precisely, since the scan generated hundreds of near-simultaneous SYN probes across two ephemeral source ports.
- The UFW rule applied for SSH hardening (§15, Action 2) needed a second look after implementation, since the source address entered scoped the rule to the target's own IP rather than the intended management host – a useful reminder to re-verify firewall rules against their intended effect, not just their "loaded" status.
- Metasploitable2 exposes an unusually large number of services simultaneously, several of which (bindshell, IRC backdoor, FTP backdoor) are Critical by design; prioritizing which findings to remediate first, and which fell outside the scope of firewall-only hardening, required an explicit risk-based decision documented in §16.

20. Conclusion

This assessment walked a full network-security workflow end to end inside an authorized lab: discovering hosts and services, capturing and analyzing live traffic, correlating an active scan with its packet-level footprint, converting raw findings into a risk-classified vulnerability assessment, and implementing and verifying real hardening changes. The Metasploitable2 target confirmed three Critical, unauthenticated remote-compromise paths (vsFTPD backdoor, root bindshell, backdoored UnrealIRCd), several High/Medium legacy-protocol and outdated-software exposures, and one internal DNS configuration anomaly worth follow-up. Three concrete hardening actions were applied and verified with before/after evidence, meaningfully reducing exposure on the two riskiest firewallable services while leaving the three service-level backdoors as the clear top priority for the next remediation pass. The exercise demonstrates the core analyst loop this training is built around: collect evidence, analyze it, identify risk, harden, and verify – not simply run tools and capture screenshots.

21. References

- Nmap Official Website – <https://nmap.org>
- Nmap Reference Guide – <https://nmap.org/book/man.html>
- Nmap NSE Documentation – <https://nmap.org/book/nse.html>
- Wireshark Official Website – <https://www.wireshark.org>
- Wireshark User's Guide – https://www.wireshark.org/docs/wsug_html_chunked/
- Wireshark Display Filter Reference – <https://www.wireshark.org/docs/dfref/>
- MITRE ATT&CK – <https://attack.mitre.org>
- CVE Program – <https://www.cve.org>
- CVE-2011-2523 (vsftpd 2.3.4 backdoor) – <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523>
- CVE-2014-3566 (SSL POODLE) – <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566>

22. Screenshots / Evidence Index

File	Task	Content
11_1_Wireshark_Capture_Started.png	Task 9	Capture started on eth0; initial NTP/ARP traffic
11_2_Captured_Packets.png	Task 9	Completed capture, 2,238 packets, 0 dropped
11_3_Top_Communicating_Hosts.png	Task 11	Endpoints (IPv4) statistics
11_4_DNS_Investigation.png	Task 11	dns filter results
11_5_TCP_Investigation.png	Task 10 / 11	tcp filter, SYN scan burst
11_6_SYN_packets.png	Task 10 / 11	tcp.flags.syn==1 filter
11_7_RST_Packets.png	Task 10 / 11	tcp.flags.reset==1 filter
12_1_Service_Version_Scan.png	Task 8	nmap -sV 192.168.17.129
12_2_Vulnerability_NSE_Scan.png	Task 8 / 12	nmap --script vuln 192.168.17.129
13_1_Before_Hardening.png	Task 13	Baseline nmap -sV scan pre-hardening
13_2_Hardening_Action_1.png	Task 13	systemctl disable --now ssh (Kali)
13_3_Firewall_Hardening.png	Task 13	UFW enabled + SSH allow rule (Metasploitable)
13_4_Telnet.png	Task 13	UFW deny 23/tcp (Telnet) + firewall status

All screenshots referenced above are included at full resolution in the 01-Nmap/Screenshots and 02-Wireshark/Screenshots project folders, and reproduced inline throughout this report at the relevant section.